Vulnerability Assessment Report

Security Analysis of Zero Bank demo site

Prepared by:
Elvina Prakash Pillay

Table of Contents

1 Executive Summary

2 Scope & Methodology

3 Risk Classification Model

4 Summary of Findings

5 Detailed Findings

6 Recommendations Summary (Action Plan)

7 Conclusion

8 Limitations

9 Appendix

10 Security Risk Dashboard

Executive Summary

Purpose of the Assessment

This assessment was conducted to evaluate the security posture of the Zero Bank demo site and identify potential vulnerabilities that could impact its confidentiality, integrity, and availability. The goal is to provide clear, actionable insights to improve overall security.

Scope

This assessment was limited to a read-only, passive review of publicly accessible components of the website.

No exploitation, authentication bypass, or intrusive testing techniques were performed.

Key Findings Summary

Total Vulnerabilities Identified	**5**
High Risk	**1**
Medium Risk	**3**
Low Risk	**1**

Overall Security Posture

Moderate Risk – Improvements Required

The application demonstrates several common security weaknesses that, if left unaddressed, could increase exposure to potential attacks.

Business Impact

The identified vulnerabilities could allow attackers to intercept sensitive information, understand how the system works, and potentially exploit exposed services. In real-world scenarios, this may lead to data breaches, loss of user trust, and reputational damage. Addressing these issues will significantly improve the safety and reliability of the application.

Scope & Methodology

Scope

Target Website:

Zero Bank demo site

Included in Scope:

- Publicly accessible web pages
- HTTP response headers and security configurations
- Basic service exposure analysis (e.g., open ports)

Excluded from Scope:

- Authentication or login-protected areas
- Any form of exploitation or attack attempts
- Brute-force, denial-of-service (DoS), or intrusive testing

Methodology

The assessment was conducted using a structured, non-intrusive approach to identify potential security weaknesses in the Zero Bank demo site.

- Passive Reconnaissance: Reviewed publicly accessible components to understand the application structure.
- Security Header Analysis: Examined HTTP headers to identify missing or misconfigured security controls.
- Service Exposure Review: Identified open ports and services to assess the external attack surface.
- Configuration Inspection: Analyzed server responses and configurations for potential information disclosure.

Tools Used

Tool	Purpose
Nmap	Identified open ports and exposed services
Browser Developer Tools	Analyzed HTTP headers and security configurations

Risk Classification Model

Risk Level	Description
High	Critical vulnerability that may lead to data breaches, unauthorized access, or complete system compromise. Immediate action is required.
Medium	Moderate vulnerability that could be exploited under certain conditions and may impact system security. Timely remediation is recommended.
Low	Minor issue with limited impact on security but should be addressed to maintain best practices and reduce overall risk exposure.

Summary of Findings

ID	Vulnerability	Risk Level	Impact
V-01	Unencrypted HTTP Communication	High	Risk of data interception and exposure of sensitive information
V-02	Missing Security Headers	Medium	Increased exposure to web-based attacks such as XSS and clickjacking
V-03	Open Ports & Services	Medium	Expanded attack surface that could be targeted by attackers
V-04	Permissive CORS Policy	Medium	Potential for unauthorized cross-origin access to resources
V-05	Information Disclosure	Low	Exposure of server and application details that may aid attackers

Detailed Findings

V-01: Unencrypted HTTP Communication

Description:

The website is accessible over HTTP instead of HTTPS, meaning data exchanged between the user and the server is not encrypted.

Why It Matters:

Without encryption, any data transmitted between the client and server can be intercepted or modified by attackers using network-based attacks such as Man-in-the-Middle (MITM). This can expose sensitive information and compromise user trust.

Risk Level:

High

Observations:

- The website is accessible via http://zero.webappsecurity.com
- Port 80 (HTTP) is open and active (confirmed via Nmap scan)

Recommendation:

- Enforce HTTPS across the entire application
- Redirect all HTTP traffic to HTTPS automatically
- Install and configure a valid SSL/TLS certificate
- Disable or restrict HTTP (port 80) where possible

V-02: Missing Security Headers

Description:

The application does not implement several important HTTP security headers that help protect against common web-based attacks.

Why It Matters:

Security headers act as protective controls in the browser. Without them, the application becomes more vulnerable to attacks such as Cross-Site Scripting (XSS), clickjacking, and data injection. This increases the overall attack surface of the application.

Risk Level:

Medium

Observations:

From the HTTP response headers, the following security headers were found to be missing:

- Content-Security-Policy (CSP)
- X-Frame-Options
- Strict-Transport-Security (HSTS)
- X-XSS-Protection

Recommendation:

- Implement a Content-Security-Policy (CSP) to control allowed content sources
- Add X-Frame-Options to prevent clickjacking attacks
- Enable Strict-Transport-Security (HSTS) to enforce secure connections
- Configure additional browser security headers as per OWASP best practices

V-03: Open Ports & Services Exposure

Description:

The target system exposes multiple open ports and services that are accessible from the internet. These services include HTTP and related application servers.

Why It Matters:

Each open port represents a potential entry point for attackers. Exposed services increase the attack surface and may contain vulnerabilities if not properly secured or updated. Attackers can use this information to target specific services running on the system.

Risk Level:

Medium

Observations:

```
PORT     STATE SERVICE    VERSION
80/tcp   open  http       Apache Tomcat/Coyote JSP engine 1.1
443/tcp  open  ssl/https?
8080/tcp open  http       Apache Tomcat/Coyote JSP engine 1.1
```

Nmap scan results showed the following open ports:

- Port 80 (HTTP) – Apache Tomcat/Coyote JSP engine
- Port 443 (HTTPS) – Secure web traffic support
- Port 8080 (HTTP) – Additional Tomcat service exposed

Recommendation:

- Close unnecessary or unused ports
- Restrict access to administrative or internal services
- Use firewall rules to limit exposure of services
- Ensure all exposed services are updated and securely configured

V-04: Permissive Cross-Origin Resource Sharing (CORS) Policy

Description:

The application is configured with a permissive Cross-Origin Resource Sharing (CORS) policy that allows requests from any origin.

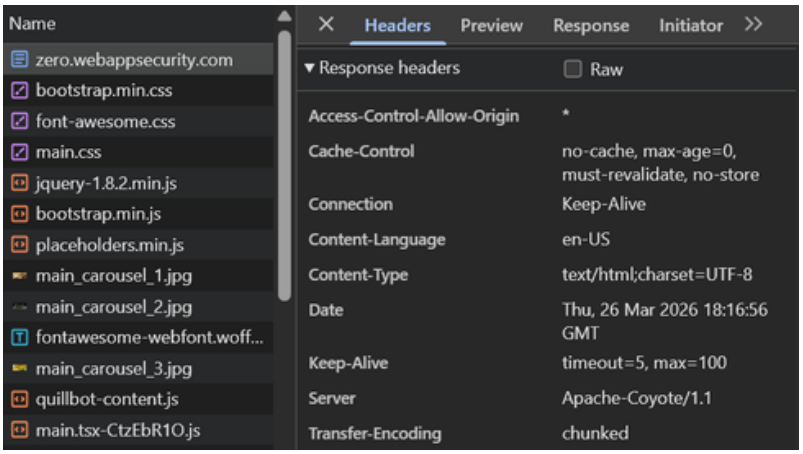
Why It Matters:

A permissive CORS policy can allow unauthorized external websites to interact with the application. This may lead to data exposure or misuse of API responses if sensitive endpoints are not properly protected.

Risk Level:

Medium

Observations:



The HTTP response header includes:

- Access-Control-Allow-Origin: *

This indicates that requests from any domain are allowed.

Recommendation:

- Restrict CORS policy to trusted and required domains only
- Avoid using wildcard (*) in production environments
- Define specific allowed origins for better access control
- Regularly review cross-origin access rules

V-05: Information Disclosure

Description:

The application reveals certain technical details in its HTTP response headers and server configuration that can provide useful information to potential attackers.

Why It Matters:

Exposing server or technology details can help attackers identify the underlying framework and search for known vulnerabilities specific to that version. While not critical on its own, it increases the ease of targeted attacks.

Risk Level:

Low

Observations:

The HTTP response headers contain the following information:

- Server: Apache-Coyote/1.1
- Additional framework and server-related details are exposed in responses

Recommendation:

- Hide or minimize server version information in HTTP headers
- Configure the web server to suppress detailed banner information
- Follow secure configuration practices to reduce information leakage

Recommendations Summary (Action Plan)

This section outlines prioritized actions to improve the overall security posture of the application based on the identified findings.

High Priority

- Enforce HTTPS across the entire application
- Redirect all HTTP traffic to secure HTTPS
- Install and properly configure SSL/TLS certificates

Medium Priority

- Implement essential HTTP security headers (CSP, HSTS, X-Frame-Options, X-XSS-Protection)
- Restrict Cross-Origin Resource Sharing (CORS) to trusted domains only
- Reduce exposure to unnecessary services and close unused ports
- Strengthen server and application configuration settings

Low Priority

- Minimize server version disclosure in HTTP headers
- Reduce information leakage from server responses
- Follow secure configuration best practices to limit technical exposure

Overall Action Plan Summary

Immediate focus should be placed on high and medium-risk issues, as they directly impact data security and system exposure. Low-risk issues should be addressed as part of ongoing security hardening efforts to improve the system's overall resilience.

Conclusion

The security assessment of the Zero Bank demo site identified multiple security weaknesses across different risk levels. The most critical issue observed was the use of unencrypted HTTP communication, which can expose sensitive data to interception.

Additionally, missing security headers, exposed services, and misconfigurations increase the overall attack surface of the application. While no active exploitation was performed, these issues represent common vulnerabilities found in real-world web applications.

Overall, the system demonstrates a moderate security posture and requires targeted improvements, particularly in encryption, secure configuration, and access control mechanisms.

Addressing the identified issues will significantly enhance the application's resilience against common web-based attacks and improve its overall security maturity.

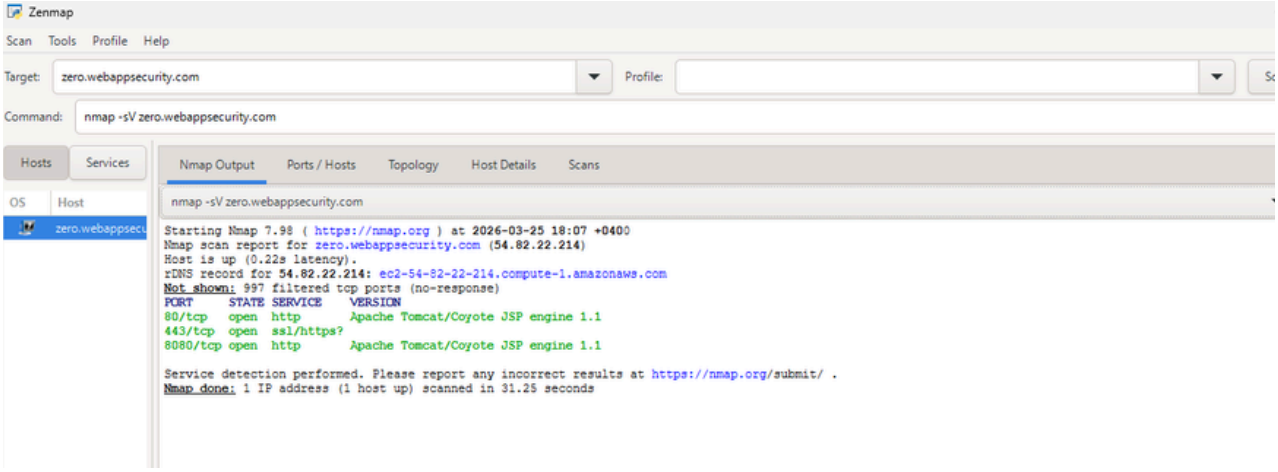
Limitations

This assessment was conducted under a strictly non-intrusive, read-only approach. No exploitation, authentication bypass, or intrusive testing techniques were performed during the evaluation.

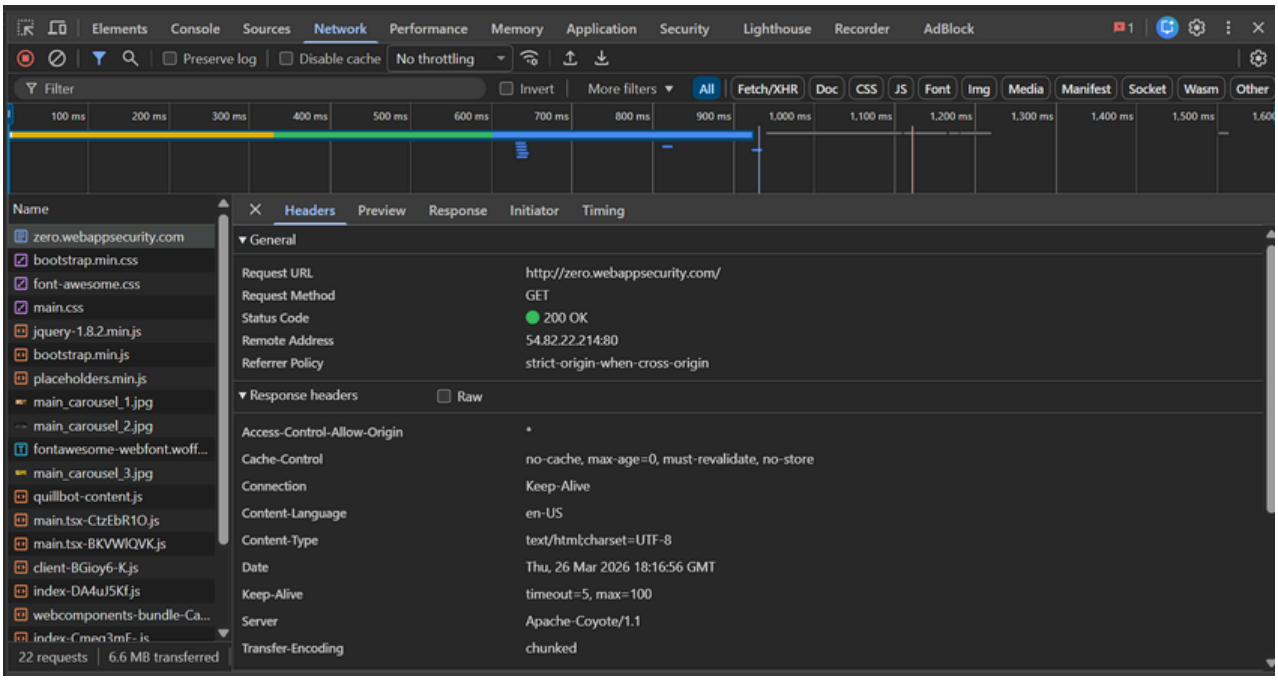
Findings are based only on publicly accessible information, server responses, and passive analysis at the time of testing. As a result, the assessment may not reflect vulnerabilities present in restricted areas or under different system states.

Appendix

Nmap Evidence

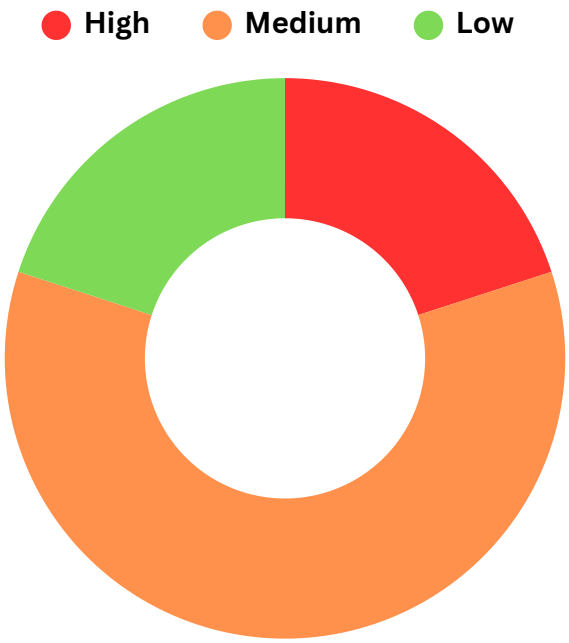


Browser Security Headers Evidence



Security Risk Dashboard

Vulnerability Distribution



Overall Risk Score

Risk Level: **Moderate Risk**

Key Risk Indicators

Category	Status
Security Headers	Missing
HTTPS Implementation	Not Enforced
Exposed Services	Needs Review
Server Information Exposure	Detected

The End